

Online Appendix

AI Agents and Sarbanes-Oxley Internal Control: Six Structural Gaps in Financial Reporting

Submitted to: *Journal of Emerging Technologies in Accounting*

Special Section: Agentic AI in Auditing and Accounting

This appendix accompanies the main paper and provides detailed analyses summarized in the main text by Table 3 (COSO component assumption–violation map) and Table 6 (summary of proposed COSO extensions).

A. COSO Principle-by-Principle Analysis

The COSO Internal Control — Integrated Framework (2013) defines five interrelated components of internal control, supported by seventeen principles (Committee of Sponsoring Organizations of the Treadway Commission, 2013). This appendix maps each component and its associated principles to AI agent behaviors, identifying where the framework’s assumptions break down. The main paper summarizes these findings in Table 3.

1.1 Control Environment (Principles 1–5)

The Control Environment is “the set of standards, processes, and structures that provide the basis for carrying out internal control across the organization” (Committee of Sponsoring Organizations of the Treadway Commission, 2013). It encompasses five principles:

Principle 1: The organization demonstrates a commitment to integrity and ethical values.

This principle assumes that the actors within the control environment possess the capacity for ethical reasoning and can be held to integrity standards through training, codes of conduct, disciplinary mechanisms, and cultural norms. AI agents do not possess ethical capacity in any meaningful sense. They optimize for objective functions. An AI agent processing journal entries does not “commit to integrity” but executes instructions within parameters. If those parameters are misspecified, the agent will produce outputs that violate ethical norms without any awareness that it has done so (Mittelstadt et al., 2016). The distinction has practical significance: integrity failures by human employees are addressed through the disciplinary and legal systems contemplated by COSO. Integrity failures by AI agents require entirely different remediation mechanisms, none of which exist in the current framework.

Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control. Board oversight assumes that the board can understand, at an appropriate level of abstraction, the processes it oversees. When financial processes are operated by humans, board members can evaluate control

effectiveness through management presentations, audit committee reports, and their own professional experience with financial operations. When financial processes are operated by AI agents, board oversight requires technical understanding of AI system behavior. Recent audit-committee and control-framework guidance treats GenAI as an oversight issue for financial reporting and ICFR, including deployment tracking, auditor evidence, and internal-control deficiency questions (Center for Audit Quality, 2024; Committee of Sponsoring Organizations of the Treadway Commission, 2026).

Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives. This principle assumes organizational structures composed of human actors with defined roles. AI agents do not sit within organizational charts. They do not report to supervisors. Their “authority” is defined by access permissions and system configurations, not by the management structures that COSO contemplates. AI agents operate outside the entity-level controls that COSO contemplates for establishing organizational accountability structures. The result is an accountability gap: when an AI agent takes an action that affects financial reporting, there is no clear “reporting line” connecting that action to an accountable human within the organizational structure (Yeung, 2018).

Principle 4: The organization demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives. AI agents are not “attracted, developed, and retained” in the human resource sense. They are procured, deployed, and decommissioned. The competence of an AI agent is not evaluated through the same mechanisms used for human employees (performance reviews, professional certifications, continuing education), and there is no COSO-equivalent framework for assessing whether an AI agent possesses the “competence” necessary to participate in financial reporting processes (Akhtar, 2023). Masli et al. (2010) examine the potential benefits of IT-related internal control monitoring technology, finding that effective IT governance requires systematic evaluation of technology capabilities; the analogous evaluation framework for AI agents does not yet exist within the COSO structure.

Principle 5: The organization holds individuals accountable for their internal control

responsibilities in the pursuit of objectives. This is the most explicit human assumption in the Control Environment component. The regulation assumes that control actors are individuals who can be held accountable through disciplinary mechanisms, professional sanctions, and personal legal liability. Autonomous agents exhibit the property of being non-accountable in any legal or organizational sense: they cannot be disciplined, terminated for cause, or subjected to personal liability. The gap is that the accountability framework has no direct target when an AI agent makes an error equivalent to a human control failure (Accountability Target Gap, G2).

1.2 Risk Assessment (Principles 6–9)

The Risk Assessment component requires the organization to “identify and assess risks to the achievement of its objectives” and to “consider the potential for fraud” (Committee of Sponsoring Organizations of the Treadway Commission, 2013). It encompasses four principles:

Principle 6: The organization specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives. In AI agent environments, the challenge is that the organization may specify financial reporting objectives clearly but may not understand how an AI agent’s operational objectives interact with those reporting objectives. An AI agent optimized for speed in invoice processing may introduce classification errors that create financial reporting risk, yet this risk may not be identified because the agent’s optimization function is not mapped to the organization’s risk assessment (Agrawal et al., 2022).

Principle 7: The organization identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed. Risk identification for AI agents requires understanding failure modes that differ from human failure modes. Humans make errors of omission, judgment, and intent. AI agents exhibit drift, hallucination, distribution shift, adversarial vulnerability, and emergent behavior (National Institute of Standards and Technology, 2023). None of these categories appear in standard COSO risk assessment templates, and most internal audit functions lack the technical expertise to identify them.

Principle 8: The organization considers the potential for fraud in assessing risks to the achievement of objectives. COSO’s fraud risk assessment framework incorporates the “fraud triangle”—pressure, opportunity, and rationalization—originating from Cressey’s work on trust violation (Cressey, 1953). AI agents experience none of these. They cannot be pressured, they do not rationalize, and their “opportunity” is a function of system access rather than organizational position. Yet AI agents can produce outputs that are functionally equivalent to fraud (overstated revenue, understated liabilities, manipulated classifications) through optimization behaviors, data errors, or adversarial manipulation. The regulation assumes fraud risk arises from human motivations; autonomous agents exhibit failure modes that produce functionally fraudulent outcomes without intent; the gap is that the risk assessment framework does not accommodate non-intentional, non-human actions that produce outcomes indistinguishable from fraud (Risk Taxonomy Gap, G4).

Principle 9: The organization identifies and assesses changes that could significantly impact the system of internal control. AI agents introduce a category of change that COSO does not contemplate: continuous, autonomous adaptation. Machine learning models update their parameters as new data arrives. Agentic systems modify their behavior based on environmental feedback. Unlike changes in human processes, which are typically discrete, documented, and approved through change management procedures, AI agent behavioral changes are continuous, implicit, and may not trigger existing change management controls (Sculley et al., 2015).

1.3 Control Activities (Principles 10–12)

Control Activities are “the actions established through policies and procedures that help ensure that management’s directives to mitigate risks to the achievement of objectives are carried out” (Committee of Sponsoring Organizations of the Treadway Commission, 2013). This component encompasses three principles:

Principle 10: The organization selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels. Traditional control activities include segregation of duties, authorization requirements, reconciliation procedures, and

physical controls. Each assumes human operators. Segregation of duties, for example, requires that no single individual controls all phases of a transaction. When an AI agent processes a transaction end-to-end (from initiation to classification to posting), the concept of segregation breaks down entirely, because a single software process performs functions that would be divided among multiple humans (ISACA, 2025).

Principle 11: The organization selects and develops general control activities over technology to support the achievement of objectives. General IT controls (GITCs), including access controls, change management, program development, and computer operations, were designed for deterministic software systems. An ERP module processes transactions according to fixed rules that can be tested and verified. An AI agent processes transactions according to learned patterns that may not be fully documented, may change over time, and may produce different outputs from similar inputs. Existing GITCs do not address the non-deterministic nature of AI agent behavior.

Principle 12: The organization deploys control activities through policies that establish what is expected and procedures that put policies into action. Policies and procedures assume human comprehension and compliance. An organization can write a policy stating that “all journal entries above \$50,000 require manager approval” and implement a procedure requiring the manager to review and sign the entry. When an AI agent generates the journal entry, the policy applies, but the procedure must be redesigned to account for the speed, volume, and opacity of agent-generated entries. In practice, many organizations deploying AI agents in financial processes have not updated their SOX control documentation to reflect the agent’s role (Ernst & Young, 2025).

1.4 Information and Communication (Principles 13–15)

The Information and Communication component requires the organization to “obtain or generate and use relevant, quality information to support the functioning of internal control” (Committee of Sponsoring Organizations of the Treadway Commission, 2013). It encompasses three principles:

Principle 13: The organization obtains or generates and uses relevant, quality information to support the functioning of internal control. AI agents both consume and produce information

within the financial reporting chain. The quality of information produced by an AI agent depends on the quality of its training data, the appropriateness of its model architecture, and the correctness of its deployment configuration. None of these quality dimensions are addressed by COSO’s information quality framework, which focuses on timeliness, completeness, accuracy, and accessibility of information produced by human-operated systems (Committee of Sponsoring Organizations of the Treadway Commission, 2013).

Principle 14: The organization internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control. This principle assumes that information can be communicated to the actors performing control functions. AI agents do not receive “communication” about objectives and responsibilities in the way that human employees do. They are configured through parameters, prompts, and constraints, a communication modality not addressed by existing internal communication frameworks.

Principle 15: The organization communicates with external parties regarding matters affecting the functioning of internal control. External communication about AI agent involvement in financial reporting raises disclosure questions that current guidance does not address. Companies are not required to disclose the extent to which AI agents participate in their financial reporting processes, the controls (if any) governing those agents, or the risk that agent behavior could produce misstatements. The SEC’s 2023 cybersecurity disclosure rules provide a partial analogy, but they do not extend to AI agent risk in financial reporting (U.S. Securities and Exchange Commission, 2023).

1.5 Monitoring (Principles 16–17)

The Monitoring component requires the organization to “select, develop, and perform ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning” (Committee of Sponsoring Organizations of the Treadway Commission, 2013). It encompasses two principles:

Principle 16: The organization selects, develops, and performs ongoing and/or separate

evaluations to ascertain whether the components of internal control are present and functioning. Monitoring of human-operated controls relies on observation, testing, and evaluation of control performance. Monitoring of AI agent-operated controls requires different capabilities: model performance monitoring, drift detection, output validation, and behavioral analysis. Internal audit functions are typically not staffed with personnel who possess these technical competencies (Institute of Internal Auditors, 2025).

Principle 17: The organization evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate. When an AI agent produces an output that constitutes a control deficiency, the deficiency may not be detectable through existing monitoring mechanisms. AI agent errors can be subtle (a gradual shift in classification patterns, an incremental bias in estimates, a systematic but small-magnitude misapplication of accounting standards) in ways that differ from human errors, which tend to be more discrete and identifiable (National Institute of Standards and Technology, 2023).

B. Detailed COSO Extension Definitions

This appendix provides the complete specifications of all 17 proposed COSO extensions for agentic AI in financial reporting environments. The main paper summarizes these extensions in Table 6. Each extension is designed to supplement (not replace) the existing COSO Internal Control — Integrated Framework (2013) by addressing the assumption–violation gaps identified in the main paper.

2.1 Control Environment Extensions (1.1–1.4)

Extension 1.1 — Agent Registry: The organization maintains a complete inventory of all AI agents that create, modify, classify, or process data within the financial reporting chain. The registry documents each agent’s identity, purpose, scope of operation, data access, model type, deployment date, and designated human accountability owner. The registry is updated within 48 hours of any agent deployment, modification, or decommissioning.

Extension 1.2 — Agent Accountability Ownership: For each AI agent in the registry, the organization designates a human “agent accountability owner” who is responsible for: (a) understanding the agent’s operational behavior at a level sufficient to evaluate its impact on financial reporting; (b) ensuring that controls governing the agent are designed and operating effectively; (c) escalating agent behavioral anomalies to management and the audit committee; and (d) attesting to the agent’s performance as part of management’s ICFR assessment.

Extension 1.3 — Agent Competence Validation: The organization establishes standards for evaluating the “competence” of AI agents participating in financial reporting processes, including: accuracy benchmarks for agent outputs in specific financial process domains; minimum explainability thresholds for agent decisions that affect material accounts; and periodic revalidation requirements to confirm that agent performance has not degraded.

Extension 1.4 — Board AI Competence: The board of directors, through its audit committee, develops sufficient understanding of AI agent deployment in financial processes to exercise effective oversight. This includes receiving periodic briefings on agent deployment, performance, and risk; designating at least one audit committee member with AI governance expertise or retaining an independent AI advisor; and reviewing the agent registry and accountability ownership designations.

2.2 Risk Assessment Extensions (2.1–2.3)

Extension 2.1 — AI Agent Risk Taxonomy: The organization adopts a risk taxonomy for AI agents in financial processes that includes, at minimum: model drift risk (the agent’s behavior changes over time as a result of data distribution shifts); hallucination risk (the agent generates outputs that are not grounded in input data); classification bias risk (the agent systematically misclassifies transactions in a specific direction); optimization misalignment risk (the agent optimizes for an objective that is inconsistent with fair financial reporting); and adversarial manipulation risk (external actors exploit the agent’s vulnerabilities to produce erroneous financial data).

Extension 2.2 — Agent Fraud Risk Assessment: The organization extends its fraud risk assessment to include non-intentional agent behaviors that produce functionally fraudulent outcomes. This assessment recognizes that AI agents cannot commit fraud (they lack intent) but can produce outputs that are equivalent in effect to fraudulent manipulation, and that the absence of intent does not reduce the financial reporting risk.

Extension 2.3 — Continuous Change Monitoring: The organization establishes monitoring mechanisms that detect changes in AI agent behavior on a continuous basis, rather than relying on discrete change management procedures. This includes automated drift detection, output

distribution monitoring, and anomaly detection systems that trigger alerts when agent behavior deviates from established baselines.

2.3 Control Activities Extensions (3.1–3.4)

Extension 3.1 — Agent Segregation of Functions: For financial processes operated by AI agents, the organization implements functional segregation: no single agent or integrated agent system performs initiation, authorization, processing, recording, and reconciliation of a financial transaction. Where functional segregation is not feasible, organizations should implement compensating controls, including mandatory human review at defined breakpoints and independent validation of agent outputs, to achieve equivalent assurance.

Extension 3.2 — Agent Output Validation Controls: For material financial processes operated by AI agents, the organization implements output validation controls that test agent outputs against independent benchmarks, human expert judgment, or alternative computational methods. Validation controls operate on a continuous basis and cover a statistically significant portion of agent-processed transactions, not merely a management-selected sample.

Extension 3.3 — Agent Determinism Requirements: For financial processes where performance is a critical audit requirement, the organization deploys AI agents that produce deterministic outputs (given the same inputs, the agent produces the same outputs) or maintains sufficient process documentation to enable reconstruction of the agent’s output for any historical transaction. This includes capturing the model version, input data, configuration parameters, and random seeds (where applicable) at the time of each agent action.

Extension 3.4 — Materiality-Based Human Review: The organization establishes risk-based thresholds for human review of agent-processed transactions that are calibrated to financial

reporting materiality, not operational efficiency. The thresholds ensure that: (a) all agent-processed transactions affecting material accounts above a defined threshold receive human review; (b) a statistically valid sample of below-threshold transactions receives human review; and (c) the sampling methodology is documented, risk-stratified, and subject to independent evaluation.

2.4 Information and Communication Extensions (4.1–4.3)

Extension 4.1 — Agent Action Audit Trail: Every AI agent action that creates, modifies, classifies, or processes financial data generates an immutable audit trail record that includes: the agent’s identity; the timestamp of the action; the input data consumed; the output data produced; the model version and configuration parameters in effect; the decision basis (to the extent explicable); and any exceptions or anomalies detected. The audit trail is maintained in a format accessible to both internal and external auditors.

Extension 4.2 — Agent Explainability Standards: For agent decisions that affect material financial statement amounts, the organization implements explainability mechanisms that provide human-readable explanations of the agent’s decision basis. These explanations need not capture the full complexity of the agent’s internal processing but must be sufficient for a qualified reviewer to evaluate whether the decision is reasonable and consistent with applicable accounting standards.

Extension 4.3 — External Disclosure: The organization discloses in its annual report, in a manner and location determined by SEC guidance: (a) the extent to which AI agents participate in financial reporting processes; (b) the material financial processes in which AI agents operate; (c) the controls governing AI agent behavior in financial processes; and (d) any material risks associated with AI agent deployment that could affect the reliability of financial reporting.

2.5 Monitoring Extensions (5.1–5.3)

The concept of continuous monitoring of AI agent operations has intellectual antecedents in the continuous auditing literature. Vasarhelyi and Halper (1991) first proposed continuous auditing of online systems, establishing the foundational principle that automated systems require automated assurance mechanisms operating at comparable frequency. Rezaee et al. (2002) extended this framework, arguing that continuous auditing requires building automated auditing capability directly into the systems being audited. Alles et al. (2008) further developed the theory for complex information systems, demonstrating that the audit of continuously operating systems requires continuous monitoring mechanisms that can detect anomalies in real time. The extensions below apply these principles to the specific context of autonomous AI agents in financial reporting.

Extension 5.1 — Continuous Agent Performance Monitoring: The organization implements automated monitoring systems that continuously evaluate AI agent performance against defined accuracy, consistency, and reliability metrics. Monitoring systems generate alerts when agent performance degrades below defined thresholds, when output distributions shift, or when agent behavior deviates from established baselines.

Extension 5.2 — Independent Agent Evaluation: The organization establishes an independent evaluation function, whether within internal audit or a separate AI assurance function, that periodically validates AI agent behavior in financial processes. The evaluation includes: testing agent outputs against known-correct results; evaluating agent behavior under stress conditions (unusual inputs, boundary cases, adversarial scenarios); and assessing whether agent controls are designed and operating effectively.

Extension 5.3 — Deficiency Escalation Protocol: The organization establishes a deficiency escalation protocol specific to AI agent deficiencies that includes: defined severity classifications for agent behavioral anomalies; escalation timelines that account for the potential speed

and scope of agent-caused misstatements; and communication channels that ensure the audit committee is informed of material agent deficiencies within the same timelines applicable to human-caused control deficiencies.

References

- Agrawal, A., J. Gans, and A. Goldfarb (2022). *Power and Prediction: The Disruptive Economics of Artificial Intelligence*. Harvard Business Review Press.
- Akhtar, Z. (2023). Artificial intelligence and the law. SSRN 4589571.
- Alles, M. G., A. Kogan, and M. A. Vasarhelyi (2008). Exploiting continuity of the audit process: A proposal for continuous auditing of complex information systems. *International Journal of Accounting Information Systems* 9(1), 1–25.
- Center for Audit Quality (2024, July). Audit committee oversight in the age of generative AI. Technical report, Center for Audit Quality. https://www.thecaq.org/wp-content/uploads/2024/07/caq_ac-oversight-in-the-age-of-genai_2024-07.pdf.
- Committee of Sponsoring Organizations of the Treadway Commission (2013). Internal control — integrated framework. Technical report, COSO.
- Committee of Sponsoring Organizations of the Treadway Commission (2026). Achieving effective internal control over generative AI (GenAI). Technical report, COSO. <https://www.coso.org/generative-ai>.
- Cressey, D. R. (1953). *Other People's Money: A Study in the Social Psychology of Embezzlement*. Free Press.
- Ernst & Young (2025). AI reshaping controllership. Technical report, EY.
- Institute of Internal Auditors (2025). Auditing AI framework. Technical report, IIA.
- ISACA (2025). The growing challenge of auditing agentic AI. Technical report, ISACA.
- Masli, A., G. F. Peters, V. J. Richardson, and J. M. Sanchez (2010). Examining the potential benefits of internal control monitoring technology. *The Accounting Review* 85(3), 1001–1034.

- Mittelstadt, B. D., P. Allo, M. Taddeo, S. Wachter, and L. Floridi (2016). The ethics of algorithms: Mapping the debate. *Big Data & Society* 3(2), 1–21.
- National Institute of Standards and Technology (2023). Artificial intelligence risk management framework (AI RMF 1.0). Technical Report NIST AI 100-1, NIST.
- Rezaee, Z., A. Sharbatoghlie, R. Elam, and P. L. McMickle (2002). Continuous auditing: Building automated auditing capability. *Auditing: A Journal of Practice & Theory* 21(1), 147–163.
- Sculley, D., G. Holt, D. Golovin, E. Davydov, T. Phillips, D. Ebner, V. Chaudhary, M. Young, J.-F. Crespo, and D. Dennison (2015). Hidden technical debt in machine learning systems. In *Advances in Neural Information Processing Systems*, Volume 28.
- U.S. Securities and Exchange Commission (2023). Release no. 33-11216: Cybersecurity risk management, strategy, governance, and incident disclosure.
- Vasarhelyi, M. A. and F. B. Halper (1991). The continuous audit of online systems. *Auditing: A Journal of Practice & Theory* 10(1), 110–125.
- Yeung, K. (2018). Algorithmic regulation: A critical interrogation. *Regulation & Governance* 12(4), 505–523.